Penetration Test Report: First Last - 192.168.0.175
Author: Ryan Andrews
Date of Assessment: December 5th, 2025
Version: 1.0


**Executive Summary** **1**
Overview 1
High-Level Test Outcomes 1
Overall Risk Rating 2
Prioritized Recommendations 2
**Test Scope and Methodology** **2**
Scope 2
Methodology 2
**Detailed Findings** **2**
**Failed Exploit Attempts** **3**
**Conclusions** **3**
Summary of Attack Path 3
Overall Security Posture 4
**Appendix** **4**
Tools Used 4


# Executive Summary

## Overview

A penetration test was conducted on the target virtual machine to identify weak points in its security posture and provide suggestions for improving that posture with the goal of preventing attacks from real adversaries. This test revealed a critical vulnerability allowing for remote code execution, resulting in the entire system becoming compromised.

High-Level Test Outcomes
The test was successful in achieving its objectives. The engagement resulted in root-level access to a container running a vulnerable FTP service. This access could be leveraged to attack other services on the host virtual machine and the broader network.

### Overall Risk Rating

Overall Risk Rating: CRITICAL
The critical rating was given due to the presence of a known vulnerable service with a readily available backdoor command execution exploit which compromises the entire machine when

exploited.

### Prioritized Recommendations

1. Immediately update or replace the vulnerable FTP service container (CVE-2011-2523).

# Test Scope and Methodology

## Scope

The scope of this penetration test was limited to the virtual machine and its services located at the following IP address:

- **In-Scope Target:** 192.168.0.175
- **Out-of-Scope:** Any other devices on the network were explicitly out of scope. No denial-of-service (DoS) attacks were performed.

## Methodology

Risk assessment was completed using common penetration testing methodology beginning with reconnaissance through Nmap port scanning. With the completed scan, vulnerabilities in exposed services were examined and ultimately exploited to show criticality.

# Detailed Findings

**3.1. Finding 1:** Reconnaissance with nmap and curl

- **Risk Rating:** Recon
- **Description:** Initial reconnaissance step by running an nmap TCP port scan using the -sS flag. Uncovered three open ports to further explore: 20, 8080, and 8888. I followed this up with a service version scan using the -sV flag to learn more about the services running on each port. This scan was not able to detect the service running on port 8888.
- **Affected Services/IPs:** 192.168.0.175
- Evidence (Proof of Concept): The following is a screenshot of the TCP port scan nmap command with the resulting output showing the three open ports.

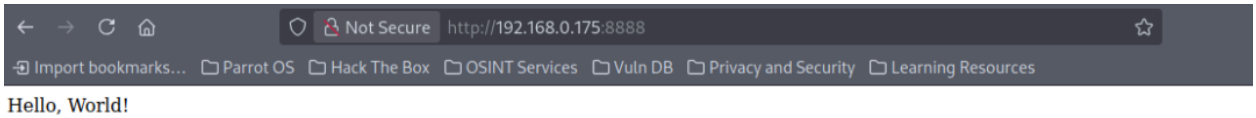
```
┌─[ryansca@cs456-180]─[~]
└──╼ $sudo nmap -sS 192.168.0.175
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-05 15:20 MST
Nmap scan report for 192.168.0.175
Host is up (0.00026s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE
22/tcp   open  ssh
8080/tcp open  http-proxy
8888/tcp open  sun-answerbook
MAC Address: BC:24:11:A8:32:B7 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 23.74 seconds
```

Following that scan I ran a service version scan as shown below.

```
┌─[ryansca@cs456-180]─[~]
└──╼ $sudo nmap -sV 192.168.0.175
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-05 15:27 MST
Nmap scan report for 192.168.0.175
Host is up (0.00025s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE         VERSION
22/tcp   open  ssh             OpenSSH 10.0p2 Debian 7~bpo12+1 (protocol 2.0)
8080/tcp open  http            nginx 1.28.0
8888/tcp open  sun-answerbook?
1 service unrecognized despite returning data. If you know the service/version,
```

At this point I'm looking primarily at the sun-answerbook service running on port 8888 as being likely vulnerable. I loaded it in a web browser to gain some more insight and was met with a blank page with the text "Hello, World!" (Pictured below).




I then ran curl to try and discover some additional information about the server. The result of the command is pictured below.

```
┌─[ryansca@cs456-180]─[/usr/share/metasploit-framework/data/wmap]
└──╼ $curl -I http://192.168.0.175:8888/
HTTP/1.1 200 OK
Server: Werkzeug/3.1.3 Python/3.12.12
Date: Sat, 06 Dec 2025 18:38:06 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 13
Connection: close
```

This revealed the server was being run using Werkzeug/3.1.3 which is typically used for developing flask applications NOT production applications so it's often misconfigured or otherwise vulnerable.

- **Remediation Steps:** n/a

**3.2. Finding 2: More Recon, but better this time**

- **Risk Rating:** CRITICAL
- **Description:** Upon running a more thorough nmap scan (using -p- to check all ports) I was able to uncover an additional open port running a version of vsftpd with known vulnerabilities and an exploit available inside of the metasploitable framework.
- **Affected Services/IPs:** 192.168.0.175
- Evidence (Proof of Concept): Below is a screenshot of the new nmap scan and the resulting output.

```
┌─[ryansca@cs456-180]─[/usr/share/metasploit-framework/data/wmap]
└──╼ $sudo nmap -p- -sV -O 192.168.0.175
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-06 12:29 MST
Nmap scan report for 192.168.0.175
Host is up (0.00022s latency).
Not shown: 65531 filtered tcp ports (no-response)
PORT     STATE SERVICE         VERSION
22/tcp   open  ssh             OpenSSH 10.0p2 Debian 7~bpo12+1 (protocol 2.0)
2122/tcp open  ftp             vsftpd 2.3.4
8080/tcp open  http            nginx 1.28.0
8888/tcp open  sun-answerbook?
```

- **Remediation:** This outdated and vulnerable service should be immediately updated to the most recent and most secure version.

# Failed Exploit Attempts

**4.1. Attempt 1: Unsuccessful directory traversal on development flask app (Not exactly an exploit)**

- **Service Targeted: Development flask application on port 8888.**

- **Description of Attempt:** I initially thought that I would be able to use a directory traversal exploit to gain more information about the development flask application running on port 8888, but after trying to run the exploit I only received error 404.
- **Reason for Failure:** There are no directories present on this application besides root ('/') likely because it's a completely barebones development application that simply prints "Hello, World!". Without any hidden directories, this service is looking more like a decoy after all.
- **Note:** The size of the word list used in this brute force exploit was fewer than 2500 words making it unlikely to cause any sort of denial of service or other damages.

**4.2. Attempt 2: Unsuccessful directory traversal on Nginx web server (Not exactly an exploit)**

- **Service Targeted: Nginx web server on port 8080.**
- **Description of Attempt:** Since Nginx is a web server (and a web proxy according to my initial nmap scan), there is a fair likelihood of hidden directories that may contain useful information.
- **Reason for Failure:** This web server has no common hidden directories to be found.
- **Note:** The size of the word list used in this brute force exploit was fewer than 2500 words making it unlikely to cause any sort of denial of service or other damages.

**4.3. Attempt 3: Partially unsuccessful exploitation of vsftpd backdoor exploit**

- **Service Targeted: vsftpd service running on port 2122**
- **Description of Attempt:** Using the well known exploit for the 2.3.4 version of vsftpd found within the metasploit framework the backdoor service was spawned successfully and a shell was found, but a session was not created.

```
[msf](Jobs:0 Agents:0) exploit(unix/ftp/vsftpd_234_backdoor) >> exploit
[*] 10.89.0.10:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.89.0.10:21 - USER: 331 Please specify the password.
[+] 10.89.0.10:21 - Backdoor service has been spawned, handling...
[+] 10.89.0.10:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Exploit completed, but no session was created.
```

- **Reason for Failure:** There is likely some issue with providing access to the shell to my machine. The LHOSTS value of my virtual machine is correctly set to my ip so theoretically there should be no problem with providing me the shell. Regardless, this vulnerability remains a critical threat.

# Conclusions

## Summary of Attack Path

An adversary would initiate the attack with a thorough service version tcp scan of the machine revealing all open ports and their details. This would expose the vulnerable version of vsftpd allowing the attacker to set up the known backdoor command execution exploit found in the

metasploit framework database or elsewhere. At this point they would have full control of the machine and could exfiltrate data, escalate privileges, or deploy a persistent backdoor.

## Overall Security Posture

The security posture of this machine is very poor as it exposes known vulnerable service with a readily available backdoor command execution exploit. Anyone with basic knowledge of nmap and a browser could exploit this machine and gain remote access in minutes. This requires an immediate update of the outdated service.

# Appendix

## Tools Used

- Nmap
- Metasploit Framework
- Netcat
- Curl